



Aula 4: Blindando o SAGA

O Pilar de Segurança na Prática

Nesta aula, aplicamos o **Pilar de Segurança do Well-Architected Framework** ao ecossistema AgroVision SAGA — implementando defesa em profundidade com IAM, KMS e Network ACLs na plataforma AWS.

O Contexto de Negócio: A Ameaça à Soberania dos Dados

O ecossistema AgroVision SAGA cresceu e agora lida com dados altamente sensíveis: a **geolocalização exata das fazendas**, os **índices de produtividade das safras** e, principalmente, os **relatórios financeiros** usados para conseguir créditos bancários verdes.



Erro 1: Credenciais Root no Código

Um desenvolvedor precisava acessar um arquivo e, para facilitar, colocou as **credenciais mestras (Root) da AWS escritas diretamente dentro do código da aplicação no GitHub**. Qualquer pessoa com acesso ao repositório passa a ter controle total sobre toda a infraestrutura da empresa.

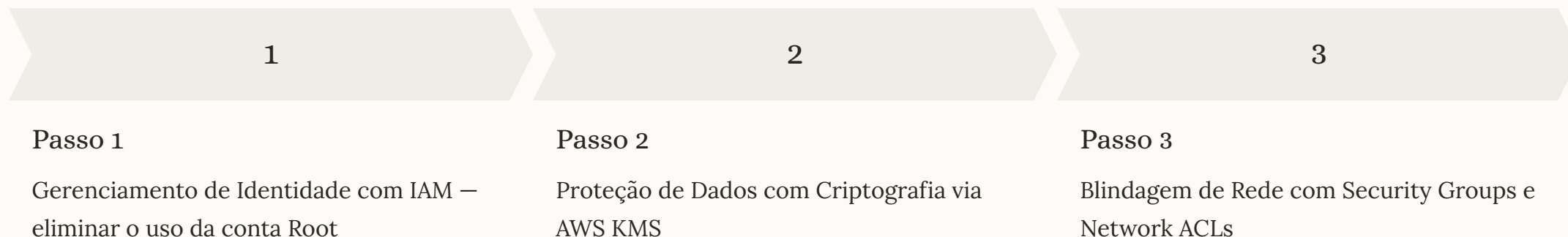


Erro 2: Dados Trafegando Sem Criptografia

Os dados de telemetria dos sensores e as imagens das plantações estão **trafegando e sendo salvos na nuvem sem criptografia**. Se um concorrente ou hacker interceptar esses dados, saberá quais fazendas estão com pragas antes do mercado — podendo **manipular o preço das commodities** ou expor dados privados dos produtores.

A Missão do Time de Arquitetos

Como Arquitetos de Soluções, nossa missão é aplicar o **Pilar de Segurança do Well-Architected Framework**, implementando **segurança em todas as camadas (Defense in Depth)** usando a plataforma da AWS — garantindo que mesmo se uma camada falhar, as outras protejam o ecossistema SAGA.



📌 **Instrução Inicial:** Certifique-se de que a região selecionada no canto superior direito do console AWS é **Norte da Virgínia (us-east-1)** antes de iniciar qualquer passo.

Passo 1: Gerenciamento de Identidade (IAM)

Eliminando a Conta Root

⚠ Por que isso importa?

A conta Root (seu e-mail principal) é o "Deus" da conta AWS. Se clonarem sua senha, a AgroVision acaba. Arquitetos criam usuários com o princípio do **Privilégio Mínimo** — dar apenas o acesso estritamente necessário para trabalhar.

Passo a Passo no Console

1. Na barra de pesquisas superior, digite **IAM** (Identity and Access Management) e clique no serviço.
2. No menu lateral esquerdo, clique em **Policies** e depois em **Create policy**.
3. Clique na aba **JSON**, apague o código existente e cole a política de leitura para o S3 (veja o card seguinte).
4. Clique em **Next**, dê o nome **AgroVision-Read-Only-S3** e clique em **Create policy**.
5. No menu esquerdo, clique em **Users** e depois em **Create user**. User name: **operador-campo-saga**.
6. Avance para permissões, selecione **Attach policies directly**, busque pela política **AgroVision-Read-Only-S3**, marque o checklist e conclua a criação.

Resultado: uma identidade isolada que, mesmo se for hackeada, **não consegue deletar nada na AWS**.

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Action": [
        "s3:GetObject",
        "s3:ListBucket"
      ],
      "Resource": "*"
    }
  ]
}
```

Esta política JSON concede acesso **apenas de leitura e listagem** ao serviço de armazenamento S3 — simulando exatamente o nível de acesso que um sensor de campo precisa, sem nenhum privilégio adicional.

Passo 2: Proteção de Dados com Criptografia (AWS KMS)

Teoria Rápida

Se um hacker conseguir invadir fisicamente o data center da AWS e roubar os discos rígidos onde estão as fotos das pragas da AgroVision, os dados precisam estar **ilegíveis (criptografados em repouso)**. O AWS KMS gerencia as chaves criptográficas que tornam isso possível.

Criando a Chave KMS

1. Na barra de pesquisas, digite **KMS** (Key Management Service) e clique no serviço.
2. No menu esquerdo, clique em **Customer managed keys** e depois em **Create key**.
3. Deixe o tipo como **Symmetric (Simétrica)** e clique em Next.
4. Alias (Nome amigável): **kms-agrovision-saga**.
5. Avance as próximas telas mantendo os padrões de administradores e usuários da chave até chegar em **Finish**.

Aplicando na Prática: Volume de Disco Criptografado

1. Vá para o console do **EC2**.
2. No menu esquerdo, em **Elastic Block Store**, clique em **Volumes** e depois em **Create volume**.
3. Escolha o tamanho de **10 GiB**.
4. Role até a seção **Encryption (Criptografia)** e marque o checklist **Encrypt this volume**.
5. No campo **KMS key**, mude de Default para a nossa chave customizada **kms-agrovision-saga**.
6. Clique em **Create volume**.

✓ Agora, qualquer dado que o sensor salvar nesse disco estará **blindado por uma chave que só a AgroVision controla** — mesmo que a AWS seja comprometida fisicamente.

Passo 3: Proteção de Infraestrutura — Blindagem de Rede Avançada

Na aula passada, criamos um Security Group que permitia tráfego web de qualquer lugar (0.0.0.0/0). Hoje entendemos a diferença crucial entre **Security Groups** (Firewall com estado, aplicado na instância) e **Network ACLs** (Firewall sem estado, aplicado na Subnet inteira).

1

Acessar Network ACLs

Volte ao painel do serviço **VPC**. No menu esquerdo, clique em **Network ACLs**. A NACL padrão permite toda entrada e saída — como uma fronteira sem polícia.

2

Criar Nova NACL

Clique em **Create network ACL**. Name: **AgroVision-NACL-Fronteira**. VPC: selecione a **AgroVision-Manual-VPC** (criada na aula 3). Clique em Create.

3

Configurar Regras de Entrada

Selecione a nova NACL, vá na aba **Inbound rules** e clique em **Edit inbound rules**. Adicione: **Regra 100** — HTTP (80), Source 0.0.0.0/0, **Allow**. Depois: **Regra 200** — All traffic, Source 0.0.0.0/0, **Deny**. Clique em Save changes.

4

Vincular às Subnets

Vá na aba **Subnet associations**, clique em **Edit subnet associations** e vincule essa NACL às suas subnets públicas. Qualquer tentativa de ataque em portas estranhas será barrada antes de chegar ao servidor EC2.

A Prova de Fogo: Simulação de Ataque

Com o ambiente configurado, é hora de testar a resiliência das políticas de segurança implementadas. Reúna a turma para as duas simulações abaixo:

Simulação 1: Vazamento de Credenciais

Tente usar as **Access Keys** criadas para o usuário **operador-campo-saga** para deletar o volume de disco criado no Passo 2 (via console ou discutindo a lógica).

O que acontece? A AWS barra instantaneamente com uma mensagem de **Access Denied (Acesso Negado)**, provando que o **privilegio mínimo salvou a empresa** de uma destruição acidental ou maliciosa. Mesmo com as credenciais em mãos, o atacante não consegue causar dano.

Simulação 2: Teste do Firewall

Tente fazer uma requisição simulada ou discuta o tráfego em uma **porta que não seja a HTTP (porta 80)** contra as instâncias da rede.

O que acontece? A **NACL derruba a conexão na hora**. A Regra 200 (Deny All) bloqueia qualquer tráfego que não seja explicitamente permitido pela Regra 100, demonstrando como a blindagem de rede impede tentativas de invasão por portas de banco de dados ou outros vetores de ataque.

- ✔ As duas simulações demonstram na prática o conceito de **Defense in Depth**: mesmo que um atacante obtenha credenciais, o privilégio mínimo limita o dano; mesmo que tente explorar a rede, o firewall bloqueia na borda.

Resumo: As Três Camadas de Segurança do SAGA

Nesta aula, implementamos o **Pilar de Segurança do Well-Architected Framework** em três camadas complementares, garantindo que o ecossistema AgroVision SAGA esteja protegido contra os principais vetores de ataque identificados no início da aula.



IAM — Identidade com Privilégio Mínimo

Criamos a política **AgroVision-Read-Only-S3** e o usuário **operador-campo-saga** com acesso restrito apenas à leitura do S3. A conta Root foi isolada, eliminando o maior risco de comprometimento total da infraestrutura.



KMS — Criptografia em Repouso

Criamos a chave customizada **kms-agrovision-saga** e aplicamos criptografia a um volume EBS de 10 GiB. Todos os dados de telemetria e imagens de plantações agora estão ilegíveis para qualquer agente externo, mesmo em caso de invasão física.



Network ACL — Blindagem de Rede

Criamos a **AgroVision-NACL-Fronteira** com regras explícitas: Allow HTTP (porta 80) e Deny All demais tráfegos. Vinculada às subnets públicas, ela forma a primeira linha de defesa antes mesmo de o tráfego chegar às instâncias EC2.

